Security Testing Reports and Remediation Tracker

Ref: 2.6
Product: iConnect Plus
Organisation: Cache Digitech
Classification: Internal — Confidential
Version: 2.0
Date: 2026-11-03
Deployment model: On-premises (Cache Digitech premises) · VPN for remote access
Audience: Security team, platform engineering, auditors, VAPT vendors

---

1. Purpose

Track **SAST**, **DAST**, **dependency scanning**, and **VAPT** activities and remediations for iConnect Plus targeting the **on-premises** deployment (internal URL, VPN context).

---

2. Scope of testing

Layer	In scope	Notes
FastAPI `/api/v1`	Yes	Cookie auth, RBAC, rate limits
Next.js admin	Yes	XSS, CSRF protections via SameSite cookies
ESS app	Yes	Login CAPTCHA optional
Infrastructure	Partial	IT owns network/VPN; app team owns containers
MinIO / Postgres	Config review	Not internet-exposed

Historical code references to VAPT (e.g. ClamAV 7.1.25, session binding) exist in `apps/api` — formal reports should be attached when available.

---

3. Testing register (template)

Test ID	Type	Tool / vendor	Target environment	Scheduled date	Report location	Status
SEC-001	SAST	**Template / Pending sign-off**	CI / repo	—	—	Not started
SEC-002	Dependency scan	**Template / Pending sign-off**	CI	—	—	Not started
SEC-003	DAST	**Template / Pending sign-off**	UAT (VPN)	—	—	Not started
SEC-004	VAPT	**Template / Pending sign-off**	UAT or prod read-only	—	—	Not started

> *No signed audit dates are recorded in this pack until official reports are filed.*

---

4. Remediation tracker

Finding ID	Source (SEC-xxx)	Severity	Description	Affected component	Owner	Target date	Fix version / PR	Retest	Status

—	—	—	*No open findings logged*	—	—	—	—	—	—

Severity definitions

Level	Definition	SLA (template)
Critical	Exploit without auth; data breach	7 days — **Template / Pending sign-off**
High	Auth bypass; privilege escalation	30 days
Medium	Defense in depth gaps	90 days
Low	Informational	Next release

5. Known security controls implemented (code baseline)

Control	Reference
HttpOnly JWT cookies	`apps/api/src/core/config.py`
MFA TOTP	`auth_service.py`
ClamAV upload scan	`shared/antivirus.py`
API docs disabled by default	`ENABLE_API_DOCS`
Refresh reuse detection	`REFRESH_REUSE_DETECTION`
Privileged shorter JWT	`JWT_PRIVILEGED_ACCESS_TOKEN_EXPIRE_MINUTES`

6. Evidence attachment checklist

Artifact	Required for audit	Location
Signed VAPT report PDF	Yes	**Template / Pending sign-off**
SAST scan export	Yes	**Template / Pending sign-off**
DAST scan export	Yes	**Template / Pending sign-off**
Remediation sign-off	Yes	§4 above

7. Related documents

Ref	Document
2.1	Application Security Requirements
1.7	Infrastructure Shared-Responsibility Matrix

Approval: Template / Pending sign-off